SOP-RISK AND OPPORTUNITY MANAGEMENT

[CONFIDENTIAL]
[UTTHUNGA]
[IndiQube, South Summit, South End Rd, Vijayarangam Layout, Bengaluru, Karnataka 560004]

Contents

1 Purpose 6
2 Scope 6
3 Abbreviations 6
4 Terms and Definitions 6
5 Responsibilities 7
6 RACI 8
7 SIPOC 9
8 Overall Process Flow Chart 11
9 Process Description 13
9.1 Organization Level Risk Management 13
9.1.1 Risk Management for Organization level 13
9.1.1.1 Establish the Risk Management Framework 13
9.1.1.2 Risk Identification 13
9.1.1.3 Risk Assessment 14
9.1.1.4 Risk Prioritization 14
9.1.1.5 Develop Risk Mitigation Plan 15
9.1.1.6 Implement Risk Mitigation Plan 15
9.1.1.7 Risk Monitoring and Reporting 16
9.1.1.8 Risk Communication 16
9.1.1.9 Review and Adjust 17
9.1.2 Continuous Improvement 17
9.1.3 Develop and Implement Contingency Plan 17
9.2 Project and Department Level Risk Management 18
9.2.1 Risk and Opportunity Management Preparation 18
9.2.2 Identify and Document Risks & Opportunities 18
9.2.3 Risk Assessment for project 18
9.3 Risk Assessment for Support functions 20

9.3.1 Identification of risks 20

9.3.2 Prepare Risk Mitigation Plan: 20

9.3.3 Residual risk assessment 21

10 Information Security requirements 21

11 Metrics 21

12 References 21

13 Annexures 22

14 Forms 22

CHANGE HISTORY

This section describes the details of changes that have resulted in the current document.

SL. No.	Document Version No.	Change Description	Reason For change	Prepared By & Date	Reviewed By & Date	Approved By & Date
01	0.1	Draft	Implementation of the Integrated Management System	Sushmitha S 04-07-22		
02	Issue B Version 1.0	Revised the Document to suit the requirements for implementation of the integrated management system			Megha K 06-07-22	Rama G 08-07-22
03	Issue B Version 1.1	Revised the Document for risk management for project like small, medium, large projects and explained about project risk assessment	Add the information about small, medium, large projects and explained about project risk assessment	Obul Prasad Reddy 25-06-23	Santhosh V 28-06-23	Rama G 30-s06-23

04	Issue B Version 1.2	Revised the Document for risk management for Organization, Department level & Project level.	Added Organization Level, Department, project & Support function level section with updated Flow chart	Sachin Aramani 20-Sep-23	Anitha N 26-Sep-23	Santosh V 07-Oct-23
05	Issue B Version 1.3	Document formatting done as per document guidelines		Vanavee P 27-Nov-24	Anitha N 5-Feb-25	Santosh V 7-Feb-25
06	Issue C Version 1.0	Review of document	New version update of IMS	Anitha N 01-08-2025	Santosh V 08-Aug-25	Sanmangala M S 14-08-2025

1 Purpose

The purpose of this document is to define a procedure for managing the Risks and Opportunities at Organization level, Department level and Project level by considering the context of the organization, interested party needs & expectations and information security management.

2 Scope

Applicable to all departments, all core processes including support functions of Utthunga

3 Abbreviations

a. R&O – Risk and Opportunity

b. RM – Risk Management

c. CFT – Cross Functional Team

4 Terms and Definitions

a. Risk: effect of uncertainty

b. Opportunity: set of circumstances that makes it possible to do improvement to process

c. Internal Context: internal environment in which the organization seeks to achieve its objectives.

d. External Context: external environment in which the organization seeks to achieve its objectives

e. Interested Party: person or organization that can affect, be affected by, or perceive themselves to be affected by a decision or activity.

f. Context of the organization: combination of internal and external issues that can influence an organization's approach to developing and achieving its objectives.

g. Triggers: the 'things' that happen which require the implementation of the plan.

h. Response plan: outlines what will be done in response to the trigger.

i. Stakeholder engagement: sharing the risk occurrence and the implementation of the plan with key or primary stakeholders.

j. Timeframes: consideration of how soon after the trigger or the risk a response action will be taken.

k. Likelihood: how likely it is that the risk will occur.

l. Consequence: the level of consequence or effect of the risk occurring.

m. Impact: the numeric rating of the financial, operational, or reputational severity that results from a risk event occurring with existing controls.

n. Preparedness: The effectiveness of controls (i.e., training, testing, business continuity) currently in place to address an identified risk.

o. Risk Appetite: The level of risk an organization is willing to accept in pursuit of its objectives.

p. Velocity: The speed at which a risk can materialize and impact an organization.

q. Acceptance: Accepting the risk and its consequences, either because the risk is too difficult or too expensive to mitigate, or because the potential benefits outweigh the potential consequences.

r. Avoidance: Avoiding the risk entirely by not engaging in the activity that could result in the risk.

s. Reduction: Reducing the likelihood or impact of the risk by implementing risk management controls or safeguards. This could involve implementing security measures, redundancy systems or establishing procedures and guidelines.

t. Transfer: Transferring or sharing the risk to another party, such as through insurance or outsourcing to a third-party provider

u. Exploitation: Actively seeking opportunities to take advantage of the positive aspects of a risk, such as a new market opportunity or emerging technology.

5 Responsibilities

a. Senior Management shall establish Risk management committee by selecting SMEs from each department

b. Risk Management Committee shall formulate Risk Management Policy

c. Project Manager shall conduct the Risk Assessment at the beginning of every project/Sprint/Milestone

d. Support Function Head shall conduct Risk assessment regularly at the beginning of every month or as and when required based on the Risk occurrence.

6 RACI

Process	Responsible	Accountable	Consulted	Informed
Risk Management Organization Level	Risk Management Committee	Quality Head		CEO, stakeholders
Risk Identification	Risk Management Committee	Quality Director	Quality Head	CEO, stakeholders
Risk Assessment	Risk Management Committee	Quality Director	Quality Head	CEO, stakeholders
Risk Prioritizing	Risk Management Committee	Quality Director	Quality Head	CEO, stakeholders
Develop and Implement Mitigation & Contingency plan	Risk Management Committee	Quality Director	Quality Head	CEO
Risk & Opportunity Management Project level / Department level	Department Member / Project team	Department Head/PM	Quality Director/ PE owner	Client, Project team, Senior Management
Risk & Opportunity identification and documenting	Department Member / Project team	Department Head/PM	Quality Director/ PE owner	Client, Project team, Senior Management
Risk Assessment	Department Member / Project team	Department Head/PM	Quality Director/ PE owner	Client, Project team, Senior Management

Risk Prioritizing	Department Member / Project team	Department Head/PM	Quality Director/ PE owner	Client, Project team, Senior Management
Develop and Implement Mitigation & Contingency plan	Department Member / Project team	Department Head/PM	Quality Director/ PE owner	Client, Project team, Senior Management

7 SIPOC

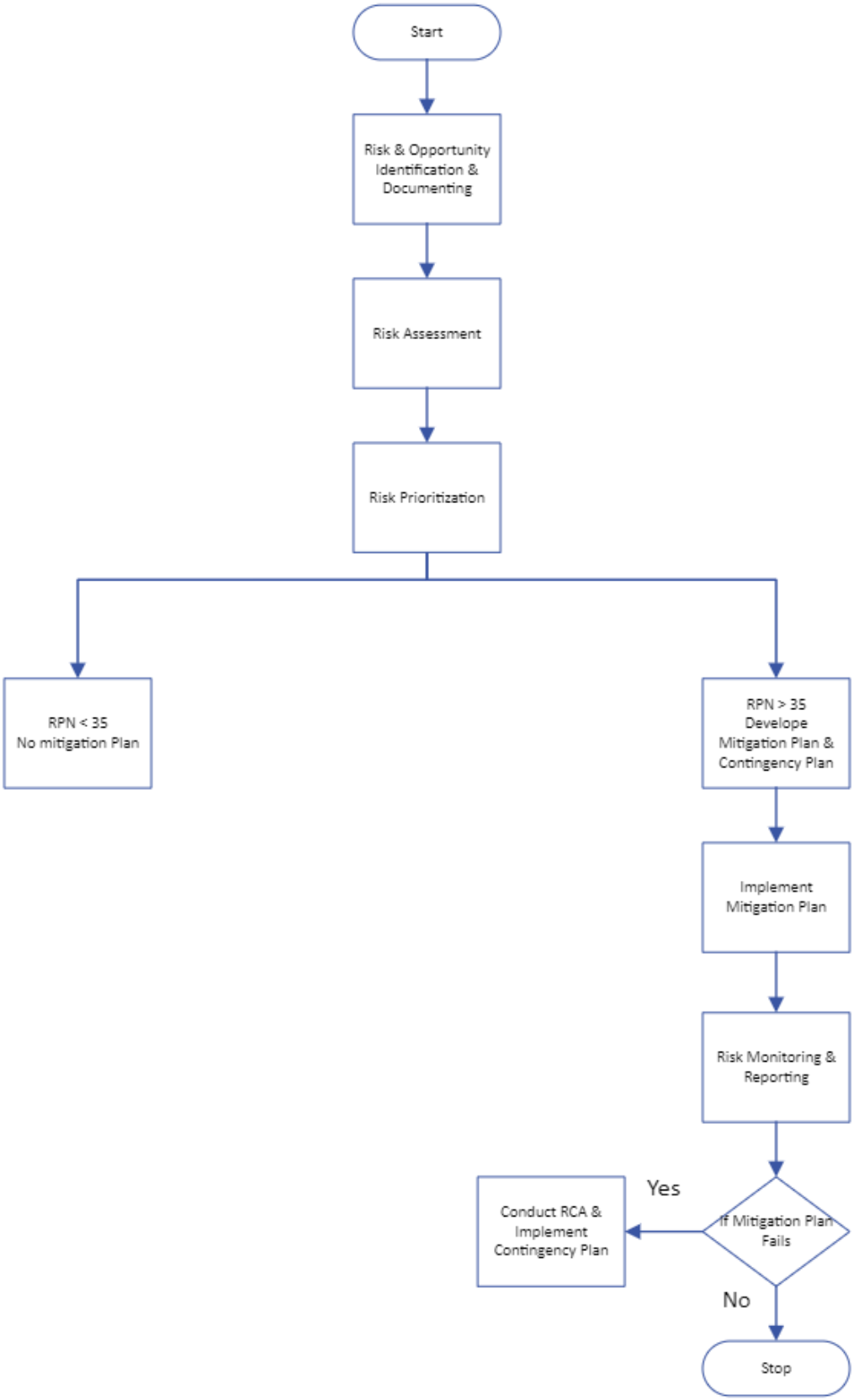
Process	Supplier	Input	Process	Output	Customer
Risk Identification process	Risk management Committee, Project/ Department manager, Client	Internal and External factors, Issues based on project assessment	Risk Identification Brainstorming Consulting SMEs Conducting periodic Risk assessments	Documented Risk Register	Project team, Department members
Risk Assessment	Project team/Department member, Customer	Documented Risk Register	Assessment of each identified Risk quantitatively and qualitatively	Documented Risk Register with Assessments	Project team, Department members
Risk Prioritization	Risk management Committee, Project team/Department member	Documented Risk Register with Assessments	Each risk is prioritized based on likelihood, Impact & Velocity Each risk is given Risk Priority Number	Documented Risk Register with RPN	Risk management Committee, Project team, Department members

Develop & Implement Risk Mitigation plan & Contingency Plan	Risk management Committee, Project team, Department members	Documented Risk Register with RPN	Mitigation & Contingency plan will be developed by Brainstorming with stakeholders. Identifying the action owner and target date	Documented Risk Register with Mitigation and Contingency Plan	Risk management Committee, Project team, Department members, Action owner, Client
Report Monitor and Review	Risk management Committee, Project team, Department members, Action owner	Documented Risk Register with Mitigation and Contingency Plan	Risk Management Committee, Quality team will monitor the implemented mitigation plan. In the event of failure of Mitigation plan, RCA will be conducted, and contingency plan will be carried out	RCA report, Lesson Learnt	Risk management Committee, Project team, Department members, Action owner, Client

8 Overall Process Flow Chart

Organization Level Risk Management

Project/ Department Level Risk Management



9 Process Description

9.1 Organization Level Risk Management

Risk Management process considers all functions and priorities of the organization. It places a strong emphasis on project delivery, data security, compliance, business continuity and client satisfaction while also addressing other operational and financial risks that may affect the organization.

9.1.1 Organization level Risk Management

9.1.1.1 Establish the Risk Management Framework

Utthunga shall set up Risk management committee comprising representatives from key functions like IT, Software Delivery, Sales, HR, Admin, Process Excellence, Finance, and Legal. This committee shall meet at least 2 times a year.

The Risk management committee shall determine risk appetite based on factors such as industry standards, client requirements, and financial constraints.

A Formal Risk management policy that outlines the organization's commitment to managing risks, including a focus on data security and client confidentiality shall be formulated by the Risk management committee. The policy shall be subject to review at least once in two years.

9.1.1.2 Risk Identification

Conduct regular risk assessments to Identify risks related to organization objectives, operations and stakeholders including client satisfaction, employee retention etc.

Establish the context by defining the scope of the risk assessment, identifying relevant stakeholders, and clarifying the organization's objectives and risk appetite.

Brainstorm potential risks that could impact the organization (refer Annexure 1,2,3,5,6) by various methods, such as conducting interviews, holding workshops, or reviewing historical data.

Identified potential risks can be categorized based on their type or source. Categories of risks include strategic, financial, operational, compliance and reputational risks.

Risk identification process shall be a continuous process that should be reviewed and updated at the beginning of every month to ensure that new risks are identified, and existing risks are appropriately managed.

Maintain a centralized risk register that document identified risks, their potential impact, and their likelihood of occurrence, categorized by function.

Risk which was identified at BU/Department level and has an impact on organization should be included in centralized Risk Register

9.1.1.3 Risk Assessment

Evaluate identified risks using both qualitative and quantitative analysis. The goal of the assessment phase is to understand what problems or opportunities a risk might cause and to determine the magnitude of the risk for prioritization in a later step. When assessing and rating risks, the following factors are considered.

- Likelihood: This factor measures the probability of a risk event occurring.
- Impact: This factor measures the potential consequences of a risk event.
- Velocity: This factor measures how quickly a risk event can materialize and cause harm.
- Preparedness: This factor measures the organization's level of preparedness to handle the risk.

9.1.1.4 Risk Prioritization

Prioritize risks based on their significance to the organization, considering the potential impact.

Each risk must be assessed and prioritized by assigning a risk rating score.

Ensure that resources are allocated to the most significant risks and appropriate measures are taken to protect stakeholders and the objectives.

The following methodology is used for rating risks:

Risk Rating = (Impact + Velocity) x Likelihood

Note:

1. ***The impact and likelihood factors are assessed on a scale of one to five, with higher numbers indicating a greater impact or probability of occurrence.***
2. ***The velocity and preparedness factors are assessed on a scale of one to four, with higher numbers indicating an increasing speed to occurrence and lack of existing controls. Though not included as part of the risk ranking formula,***
3. ***The preparedness factor is used when prioritizing risks to provide management with an added level of maturity and detail to the risk discussion.***

- The risk rating formula shall be used to calculate a numerical score for each identified risk, which is then used to prioritize risks and determine the appropriate risk management strategies.
- Risks with higher risk rating scores in the risk register shall be given priority attention and resources for risk management and mitigation effort.

9.1.1.5 Develop Risk Mitigation Plan

Once risks are identified and prioritized, a range of strategies for mitigating risks can be utilized to treat the risks. Create detailed mitigation plans for high-priority risks.

Policies, procedures, and controls shall be created to enable the organization to keep risks within acceptable ranges.

A risk mitigation plan shall outline the specific strategies and actions that will be taken to mitigate the risk.

The plans define roles and responsibilities for risk mitigation, establish timelines for completion and identify resource requirements. Each function shall allocate the necessary resources to implement risk mitigation plans effectively.

Risk Can be strategically Accepted/Avoided/Reduced /Transferred or Exploited

9.1.1.6 Implement Risk Mitigation Plan

Mitigation action shall be implemented to reduce the likelihood or impact of identified risks that could negatively impact an organization's objectives.

Strategy may involve implementing new procedures, guidelines, or controls, or modifying existing ones.

Communication and training shall be planned for effective implementation of the selected risk mitigation plans.

Stakeholders shall be informed about the Mitigation plans as well as their roles and responsibilities in the implementation process.

Training shall be conducted to ensure stakeholders have the necessary skills and knowledge to implement the mitigation plans effectively.

9.1.1.7 Risk Monitoring and Reporting

Continuously monitor all identified risks across functions, particularly those associated with client projects as per the Project/Department plan

Define Key Risk Indicators (KRIs) specific to each function and project. Monitor these indicators to provide early warnings of potential issues.

Provide regular risk status updates to the Risk Management team, senior management, and relevant stakeholders, highlighting trends and emerging risks.

Regular monitoring and reviewing the effectiveness of the implemented mitigation plans to ensure that they remain effective and relevant. Adjustments to Risk Rating should be made based on changes in the risk environment, organizational priorities, or other factors.

Risk reporting informs the day-to-day decision-making by helping management identify the risks facing their organizations.

RCA should be conducted for the Mitigation actions failed and lessons learnt to be captured in centralized repository.

9.1.1.8 Risk Communication

Establish Internal Communication to foster a culture of risk awareness among employees. Ensure that risk information is communicated effectively within and across functions.

Organization level risk which is identified during project/Department/BU level should be moved to Organization Risk register

9.1.1.9 Review and Adjust

Semi-annual reviews of the Risk Management process shall be conducted to ensure its effectiveness and alignment with organizational goals.

Risk management strategies should be adjusted as the risk landscape evolves or as new client requirements emerge.

9.1.2 Continuous Improvement

Any incidents or issues shall be analyzed to identify areas for improvement in the Risk management process. Risk and Incident reports shall be maintained in the central repository.

Regular training shall be provided to employees in areas such as data security, opportunity management, risk-based thinking, project risk management, and client communication as per the organization process training policy.

9.1.3 Develop and Implement Contingency Plan

Specific events which could trigger the implementation of the contingency plan should be identified during Risks assessment.

Roles and responsibilities, timeframes, or processes, where the plan occurs and how it will be implemented should be documented.

Guidelines to report and communicate the processes should be defined. How stakeholders will be engaged, who will send the information, how frequently, and how soon after risks occur the communication needs to be shared should be documented.

Contingency plan should be monitored and reported, ensuring it is up to date with all potential risks by owner of the contingency plan.

9.2 Project and Department Level Risk Management

9.2.1 Risk and Opportunity Management Preparation

a. Identify Risk & Opportunity Sources and Categories: Department Head/PM along with their team members shall identify the sources of risks & opportunities and their categories. The sources could be as varied as business risks & opportunities, process related, product related, customer, technology, regulatory, Internal Context of business, External Context of Business etc.

b. Define Risk & opportunity Parameters: The Quality Team shall define risk & opportunity parameters. The definition of parameters includes the process for evaluating, categorizing, and prioritizing risk & opportunities. Refer Risk Management template.

9.2.2 Identify and Document Risks & Opportunities

a. Risk & Opportunity identification is a continuous process throughout the lifecycle of the project. The Department Head/PM along with their team members shall specifically identify the risk & opportunities considering every stage of their activities and perform risk & opportunity analysis.

b. Risk and opportunity assessments for Projects and Support shall be carried out on the following basis.

- Issues and Asset based risk Assessment.
- Interested Party Needs and Expectation
- Opportunity Management

9.2.3 Risk Assessment for project

Project Risk Assessment is conducted based on the type of Project. Project is Classified as Small, Medium, and Large depending on the project Value and effort required.

The following table gives the criteria for small, medium, and large.

Classification	Project Value $	Effort (person Months)
Large	150000	> 60
Medium	30000-149000	12-59
Small	1-30000	01-11

Based on the type of project, respective Risk Management template to be used

a. Document the project Number, project Name and Client name for the projects for which risk assessment to be conducted.

b. Identify the Potential risk by creating a list of every possible risk and opportunity the team can think of.

c. focus on the threats which could miss out on the chance to deliver unexpected value to the customer.

d. In the risk description explain about the risk that impacts the project and which stage of the project risk occurs.

e. On identifying the risk, the impact of risk can be explained in impact description.

f. If the Impact of the Risk is at the account/Organizational level, such risk to be promoted to Organization Risk Register

g. Describe the Probability of occurrence of risk. Risk occurrence can be Low, medium, High based on probability of occurrence.

h. Describe the Impact on ISMS affecting the preservation of confidentiality, integrity and availability of information.

i. Classify the impact of risk on project like low, medium, high.

j. Calculate the priority score by taking probability (Low, medium, high) and impact (Low, medium, high) Priority Score = (Probability + 2*Impact) / 3)

k. Risk with higher priority score should be identified as Early warning and communicate to Senior Management in governance Meeting.

l. Based upon the Probability and impact, priority shall be calculated. on considering priority score, risk can be mitigated. Below is the priority score table.

Priority Score	Action Plan
< 35	Mitigation plan not required
36 – 50	Mitigation plan desirable but not required
50 – 70	Mitigation plan required. Make maximum attempts to mitigate risk to reduce priority
>= 70	Risk must be mitigated until priority drops below this category. The project cannot proceed with any “very high” priority risks

m. Regular monitoring and reviewing the effectiveness of the implemented mitigation strategies ensures that they remain effective and relevant.

Adjustments to Risk Rating should be made based on changes in the risk environment, project priorities or other factors.

n. If the Risk occurs, then immediately contingency plan to be kicked in and RCA to be conducted to know the cause of failed mitigation Strategy.

o. Risk Assessment for the projects to be conducted at the beginning of every project/sprint/ Milestone or as per the project planning document.

Note: For Small project (As per above table) – Use Small project Risk Management template

9.3 Risk Assessment for Support functions

Risk Assessment for support function shall be conducted regularly at the beginning of every month or as and when required based on the Risk occurrence.

9.3.1 Identification of risks

a. Identify the potential Risks based on factors such as Internal and External context, Business Risks Interested parties, information security and Asset valuation perspective. Refer Annexure (1,2,3,4,5,6)

b. Describe the Impact on ISMS affecting the preservation of confidentiality, integrity, and availability of the information / information asset.

c. Identified risk shall be described in risk description.

d. Risk which is identified as organization wide shall be moved to Organization Risk register.

e. Evaluate the Occurrence (O) - as per Annexure 7 - Risk Rating Table

f. Evaluate the Severity (S) - as per Annexure 7 - Risk Rating Table

g. Calculate Risk score - product of severity and occurrence (S * O) - and classify the risk level as per Annexure 7 - Risk Rating Table

9.3.2 Prepare Risk Mitigation Plan:

Based on the priority of risk, the team shall prepare a risk mitigation plan. Mitigation consists of actions which reduce the risk exposure by lowering the probability of the risk, lowering the impact of the risk. The Mitigation plan can include:

a. avoiding the risk by deciding not to start or continue with the activity that gives rise to the risk.

b. taking or increasing the risk to pursue an opportunity.

c. removing the risk source.

d. changing the likelihood.

e. changing the consequences.

f. sharing the risk (e.g., through contracts, buying insurance).

g. retaining the risk by informed decision.

9.3.3 Residual risk assessment

a. Monitor the Residual risk assessment - after every quarter from the date of entry.

b. Evaluate the Occurrence (O) - as per Annexure 7 - Risk Rating Table / Annexure 8 - Asset based Risk Rating Table

c. Evaluate the Severity (S) - as per Annexure 7 - Risk Rating Table / Annexure 8 - Asset based Risk Rating Table

d. Calculate Risk score - product of severity and occurrence (S * O) - and classify the risk level as per Annexure 7 - Risk Rating Table / Annexure 8 - Asset based Risk Rating Table

e. Document the risk decision.

f. close if risk assessment is effective.

g. open if risk assessment is effective but the risk is significant because or severity of impact.

h. re do - if risk assessment is not effective - if no reduction in score is observed then the risk is re assessed by following steps as mentioned above

10 Information Security requirements

In the risk management a set of security controls that protect the confidentiality, availability, and integrity of assets from threats and vulnerabilities needs to be identified and mapped by the risk assessors.

11 Metrics

a. Number of Risk Identified

b. Number of Risk Occurred

c. Number of Risk Mitigated

d. Cost Benefit Analysis for Risk & Opportunity

12 References

a. ISO 9001 Clauses 4.1, 4.2, 6.1.1

b. ISO 27001 Clauses 4.1, 4.2, 6.1.1, 6.1.2, 6.1.3, 8.2, 8.3

c. ISO 31000:2018 - Risk management — Guidelines

13 Annexures

a. Annexure 1- Details of Internal Context

b. Annexure 2- Details of External Context

c. Annexure 3- Details of Interested Parties

d. Annexure 4 – Asset Valuation Matrix

e. Annexure 5- Details of ISMS Outcomes

f. Annexure 6 – Business risk details

g. Annexure 7 – Risk rating table

h. Annexure 8 – Asset based risk rating table

i. Annexure 9 – Opportunity impact to IMS

j. Annexure 10 – Opportunity rating table

14 Forms

Risk Management template

Annexure 1- Details of Internal Context
1. Vision, mission, and values. 2. Governance, organizational structure, roles and accountabilities. 3. Strategy, objectives, and policies. 4. The organization's culture. 5. Standards, guidelines, and models adopted by the organization. 6. Capabilities, understood in terms of resources and knowledge (e.g., capital, time, people, intellectual Property, processes, systems, and technologies). 7. Data, information systems and information flows. 8. Relationships with internal stakeholders, considering their perceptions and values. 9. Contractual relationships and commitments. 10. Interdependencies and interconnections.

Annexure 2- Details of External Context
1. The social, cultural, political, legal, regulatory, financial, technological, economic, and environmental
2. Factors, whether international, national, regional, or local.
3. Key drivers and trends affecting the objectives of the organization.
4. External stakeholders' relationships, perceptions, values, needs and expectations.
5. Contractual relationships and commitments.
6. The complexity of networks and dependencies.

Annexure 3- Details of Interested Parties	
Types of Internal interested parties:	**Needs and expectations:**
1. Employees contractors and	Shared culture, attitudes Professional development, prompt payment health and safety, work/ life balance, employment and data security.
2. Shareholders	Profitability and strategies for growth
3. Unions and worker representatives	Representation and cooperation
Types of External interested parties:	**Possible needs and expectations:**
1. Regulators	Compliance, information security laws and ensure they are being met and reporting
2. Clients and customers	The way sensitive information is protected, Competitive pricing, reliability and value
3. Neighbors and communities	Social responsibility and engagement
4. Local Authorities and Government	Consultation and information
5. Suppliers	Beneficial supplier-client relationships
6. Certification bodies	Logo policy and certification requirement compliances
7. Competitors	Market share analysis, solicitation of talent and customers
8. Credit agencies and finance companies	On time payments and compliances
9. Emergency services	Reasonable precautions to protect the company from incidents in line with those operations.
10. Landlords	Compliance to agreement conditions
11. Non-Governmental Organizations	Voluntary principles or Codes of Practice
12. Trade associations	Comply with any membership requirements
13. Utility companies	Pay their utility bills on time, Conform to the legal requirements

Annexure 4- Details of ISMS Outcomes

ISMS risks	ISMS Consequences
1. Complicated user interface 2. Default passwords not changed. 3. Disposal of storage media without deleting data 4. Downtime 5. Equipment sensitivity to changes in voltage. 6. Equipment sensitivity to moisture and contaminants 7. Equipment sensitivity to temperature 8. Inadequate cabling security 9. Inadequate capacity management 10. Inadequate change management 11. Inadequate classification of information 12. Inadequate control of physical access 13. Inadequate maintenance 14. Inadequate network management 15. Inadequate or irregular backup 16. Inadequate password management 17. Inadequate physical protection 18. Inadequate protection of cryptographic keys 19. Inadequate replacement of older equipment 20. Inadequate security awareness 21. Inadequate segregation of duties 22. Inadequate segregation of operational and testing facilities 23. Inadequate supervision of employees 24. Inadequate supervision of vendors 25. Inadequate training of employees 26. Incomplete specification for software development	1. Breach of contractual relations 2. Breach of legislation 3. Damage caused by a third party. 4. Damages resulting from penetration testing. 5. Destruction of records 6. Eavesdropping 7. Embezzlement 8. Employees going on strike. 9. Equipment malfunction 10. Failure of communication links 11. Falsification of records 12. Fraud from a cyber criminal 13. Fraud from an internal party 14. Improper disclosure of passwords 15. Improper disclosure of sensitive information 16. Industrial espionage 17. Interruption of business processes 18. Lack of data integrity 19. Loss of support services 20. Maintenance errors 21. Malicious code 22. Misuse of information systems 23. Natural or man-made disaster 24. Phishing scams 25. Power failure 26. Sensitive data being compromised. 27. Social engineering 28. Terrorism threat in the immediate vicinity or affecting nearby transport and logistics 29. Theft of equipment 30. Theft of sensitive data

27. Insufficient software testing
28. Lack of access control policy
29. Lack of clean desk and clear screen policy
30. Lack of control over the input and output data
31. Lack of internal documentation
32. Lack of or poor implementation of internal audit
33. Lack of policy for the use of cryptography
34. Lack of procedure for removing access rights upon termination of employment
35. Lack of protection for mobile equipment
36. Lack of redundancy
37. Lack of systems for identification and authentication
38. Lack of validation of the processed data
39. Location vulnerable to flooding
40. Poor selection of test data
41. Single copy
42. Too much power in one person
43. Uncontrolled copying of data
44. Uncontrolled download from the Internet
45. Uncontrolled use of information systems
46. Undocumented software
47. Unmotivated employees
48. Unprotected public network connections.
49. User rights are not reviewed regularly
50. Employees not receiving adequate training.
51. Equipment not being replaced when it is no longer fit for purpose

31. Unauthorized access to the information system
32. Unauthorized access to the network
33. Unauthorized changes of records
34. Unauthorized physical access
35. Unauthorized use of copyright material
36. Un availability of system
37. Access to the network by unauthorized persons
38. Bomb attack
39. Bomb threat
40. Compromising confidential information
41. Concealing user identity
42. Disaster (human caused)
43. Disaster (natural)
44. Disclosure of information
45. Disclosure of passwords
46. Errors in maintenance
47. Fire
48. Flood
49. Fraud
50. Information leakage
51. Loss of electricity
52. Malfunction of equipment
53. Misuse of audit tools
54. Pollution
55. Software errors
56. Strike
57. Terrorist attacks
58. Theft
59. Thunderstroke
60. Unintentional change of data in an information system
61. Unauthorized access to the information system
62. Unauthorized changes of records
63. Unauthorized installation of software

52. Hard drives being disposed of without sensitive data having been deleted.
53. Improper cabling security and management
54. Improper change management
55. Improper internal audit
56. Improper network management
57. Improper validation of the processed data
58. Inadequate or irregular system backups
59. Inadequate physical security controls
60. Insufficient processes or technologies to prevent malicious files from being downloaded.
61. Insufficient processes or technologies to prevent sensitive data from being copied
62. Insufficient processes or technologies to prevent users from downloading unapproved software
63. No procedure for removing access rights upon termination of employment
64. No protection for mobile equipment
65. Operational and testing facilities not being properly segregated
66. Passwords not being changed from default settings
67. Passwords not being strong enough
68. Poor or non-existent access control policy
69. Poor or non-existent clean desk and clear screen policy
70. Poor or non-existent of internal documentation
71. Poor staff morale and potential for malicious action
72. Premises is vulnerable to flooding, fire or another disruptive event
64. Unauthorized physical access
65. Unauthorized use of copyright material
66. Unauthorized use of software
67. User error
68. Vandalism

Annexure 5 – Business risk details	
1. Strategic Risk	25. Accounting Risk
2. Corporate Governance Risk	26. Fiduciary Breach Risk
3. Competitive Risk	27. Counterparty risk
4. Innovation Risk	28. Tax Risk
5. Intellectual Property Risk	29. Revenue Shortfall Risk
6. Economic Risk	30. Demand Risk
7. Technological Change Risk	31. Market Competition Risk
8. Change Management Risk	32. Sales Forecast Risk
9. Project Risk	33. New Product Development Risk
10. Ethics Risk	34. Customer Relationship Risk
11. Reputational Risk	35. Brand Value Risk
12. Sustainability Risk	36. Publicity Risk
13. Profit Risk	37. Large Account Risk
14. Capital Availability	38. Location Risk
15. Asset Risk	39. Operational
16. Interest Rate Risk	40. Infrastructure Risk
17. Currency Risk	41. Maintenance Risks Risk
18. Inflation Risk	42. Product Failure Risk
19. Investment Risk	43. Product Liability Risk
20. Liquidity Risk	44. Operational Quality Risk
21. Systemic Risk	45. Production Shortfall Risk
22. Concentration Risk	46. Logistics Risk
23. Credit Risk	47. Procurement Risk
24. Fraud Risk	48. Architectural Risk

Annexure 6 – Risk rating table

Risk score (S * O)

Significance of risk / Opportunity		Severity (S)				
	Scale	Very Low (1)	Low (2)	Medium (3)	High (4)	Very High (5)
Occurrence (O)	Very Low (1)	1	2	3	4	5
	Low (2)	2	4	6	8	10
	Medium (3)	3	6	9	12	15
	High (4)	4	8	12	16	20
	Very High (5)	5	10	15	20	25

Risk level: Low risk - No action further required	Risk Level: Medium Risk - Monitor and review the risk - action can be given if needed	Risk Level: High risk - action is must

Severity scale:	Likelihood scale:
1. Does not impact any process	1. Occurs once in a year / never till now
2. Impacts internal process and can be corrected internally	2. Occurs more than once in year
3. Impacts internal process and can be corrected internally over a period of time	3. Occurs more than once in semi annual
4. Impacts customer and their delivery requirements	4. Occurs more than once in quarter
5. Impacts Legal Obligations	5. Occurs monthly or weekly or daily

Risk Criteria:

1. Severity score is equal to or more than 4
2. Any Risk above 15

Annexure 7 – Asset based risk rating table

Risk score Asset value (S * O)

Significance of risk / Opportunity		Severity (S)				
Occurrence (O)	Scale	Very Low (1)	Low (2)	Medium (3)	High (4)	Very High (5)
	Very Low (1)	1	2	3	4	5
	Low (2)	2	4	6	8	10
	Medium (3)	3	6	9	12	15
	High (4)	4	8	12	16	20
	Very High (5)	5	10	15	20	25

Risk Level is defined by Asset Value * Risk Score

Risk Criteria:

1. High
   - Severity score is equal to or more than 4
   - Any Risk above 105 – Action is must, in top priority

2. Medium
   - Between – 84 – 105 – Action can be provided if needed

3. Low
   - Below 84 – can be acceptable action is voluntary can be given if needed.

Severity scale:	Likelihood scale:
1. Does not impact any process 2. Impacts internal process and can be corrected internally 3. Impacts internal process and can be corrected internally over a period 4. Impacts customer and their delivery requirements 5. Impacts Legal Obligations	1. Occurs once in a year / never till now 2. Occurs more than once in year 3. Occurs more than once in semi annual 4. Occurs more than once in quarter 5. Occurs monthly or weekly or daily

Annexure 8 – Opportunity impact to IMS

1) Process efficiency
2) Product efficiency
3) New Technology
4) Improvement in existing technology
5) Customer experience
6) Governance of system
7) Reducing lead times
8) Improving delivery efficiency
9) Traceability management
10) Business Continuity initiatives
11) Competence Building
12) Employee satisfaction
13) Avoiding redundant steps
14) Value creation
15) Performance of IMS

Annexure 9 – Opportunity rating table

Benefit = Low (1)	Benefit = Medium (2)	Benefit = High (3)
1	2	3
Not much impact	Impact internal processes	Impacts customer